

CO3 – AT2: Port Scanning Challenge

Answer-Preparation Study Outline (Not a Final Submission)

Course: Ethical Hacking (ITA14) | Course Outcome: CO3 | Total Marks: 50

This outline is a study aid to help you build your own answers. It explains the concepts, tools, and structure the rubric expects for each question. Fill in your own screenshots, actual command output, host-specific observations, and analysis before submitting, and complete the Code of Conduct declaration yourself.

Question 1: Nmap Security Assessment

Target: 192.168.1.20

Perform a security assessment using Nmap: identify open ports and running services, analyze the purpose of each, and recommend measures to reduce the attack surface.

Concepts you need to understand

- Difference between TCP connect scan, SYN (stealth) scan, UDP scan, and version detection.
- What 'open', 'closed', and 'filtered' port states mean.
- How service/version detection (-sV) and OS fingerprinting (-O) work.
- Concept of 'attack surface' — every open port/service is a potential entry point.
- Common services and their default ports (FTP 21, SSH 22, Telnet 23, HTTP 80/443, SMB 445, RDP 3389, etc.).

Tools & example command syntax (reference only — run against the authorized lab target given to you)

Nmap – host & port discovery

Start broad, then narrow down.

```
nmap -sn 192.168.1.20
nmap -p- 192.168.1.20
nmap -sV -sC -O 192.168.1.20
```

What your analysis should cover

- List every open port found and the exact service/version reported.
- For each service, explain its normal business purpose (why an organization would run it).
- Flag services that are risky by nature (e.g., Telnet, FTP with anonymous login, outdated software versions with known CVEs).
- Discuss how an attacker could chain this information (e.g., version numbers → CVE lookup → exploit).
- Recommend concrete hardening steps: disable unused services, patch/upgrade versions, restrict access with firewall rules, replace insecure protocols with encrypted equivalents.

Mapping to the rubric — write these sections explicitly

Identification (25):

List every port/service you actually discovered from your scan output — be specific and complete.

Analysis (25):

Explain why each service exists and what risk it introduces, referencing the version/banner detected.

Linkage (20):

Connect individual findings into an overall attack-surface picture (e.g., 'these three open ports together indicate...').

Application (20):

Tie your recommendations to this specific host and the specific services found, not generic advice.

Clarity (10):

Use headings, a findings table, and numbered recommendations.

Question 2: Nikto Web Server Assessment

Target: 192.168.1.30

Assess the web server with Nikto: identify misconfigurations, outdated components, exposed files/directories, and mitigation strategies.

Concepts you need to understand

- Nikto scans for known-vulnerable server software, dangerous files/CGIs, outdated versions, and misconfigured headers.
- Difference between a misconfiguration (e.g., directory listing enabled) and a vulnerable component (e.g., outdated Apache/PHP).
- Why exposed backup files, default install pages, or admin panels are risky.

Tools & example command syntax (reference only — run against the authorized lab target given to you)

Nikto

Basic and tuned scans.

```
nikto -h http://192.168.1.30
nikto -h http://192.168.1.30 -Tuning 1,2,3,4,5
```

What your analysis should cover

- Categorize findings: outdated software, missing security headers, exposed files/directories, default credentials/pages.
- For each finding, explain the real-world risk (information disclosure, remote code execution potential, etc.).
- Discuss mitigation: patching, removing default/sample files, disabling directory listing, adding security headers, restricting access to admin paths.

Mapping to the rubric — write these sections explicitly

Identification (25):

List every distinct Nikto finding relevant to the assessment.

Analysis (25):

Explain the security implication of each finding, not just restate the Nikto message.

Linkage (20):

Show how multiple small misconfigurations combine into a larger exposure.

Application (20):

Give mitigation steps specific to what Nikto reported for this server.

Clarity (10):

Organize findings in a table: Finding | Risk | Recommendation.

Question 3: Netcat Banner Grabbing

Target: 192.168.1.40

Investigate the host with Netcat: connect to open ports, collect service banners, and analyze how attackers use banner information during reconnaissance.

Concepts you need to understand

- Banner grabbing = connecting to a service and reading the text it returns on connection (often reveals software name/version).
- Netcat as a generic TCP/UDP client — not an exploit tool, just a way to talk to open ports directly.
- Why banners matter for reconnaissance: they narrow down exact software versions to search for known exploits.

Tools & example command syntax (reference only — run against the authorized lab target given to you)

Netcat

Connect and read the banner.

```
nc -v 192.168.1.40 21
nc -v 192.168.1.40 22
nc -v 192.168.1.40 80 HEAD / HTTP/1.0\r\n\r\n
```

What your analysis should cover

- Record the exact banner text returned per port and identify the software/version it discloses.
- Explain how an attacker maps a banner to public vulnerability databases (e.g., CVE/NVD, Exploit-DB) to plan an attack.
- Discuss defenses: banner suppression/obfuscation, keeping software patched so even if the version is known it isn't exploitable.

Mapping to the rubric — write these sections explicitly

Identification (25):

List each port tested and the banner/response received.

Analysis (25):

Interpret what each banner reveals about the underlying software.

Linkage (20):

Connect banner data to the broader reconnaissance phase of the attack lifecycle.

Application (20):

Recommend banner-hardening measures specific to the services you tested.

Clarity (10):

Present a simple table of Port | Banner | Software Identified.

Question 4: Telnet Remote Administration Check

Target: 192.168.1.50

Examine the server with Telnet to determine whether remote administration services are accessible, and recommend secure alternatives.

Concepts you need to understand

- Telnet transmits data (including credentials) in plaintext — a fundamental security weakness.
- Why open Telnet on a server is treated as a high-risk finding almost by default.
- SSH as the secure, encrypted alternative for remote administration.

Tools & example command syntax (reference only — run against the authorized lab target given to you)

Telnet

Test connectivity to the admin service.

```
telnet 192.168.1.50 23
```

Nmap (to confirm the state first)

```
nmap -p 23 192.168.1.50
```

What your analysis should cover

- State clearly whether port 23 is open/accessible and what banner/login prompt appears.
- Explain the risk: credential interception via network sniffing, session hijacking, no encryption.
- Recommend disabling Telnet and migrating to SSH (with key-based auth), plus network-level restrictions (firewall/VPN/jump host).

Mapping to the rubric — write these sections explicitly

Identification (25):

State the port status and service confirmed.

Analysis (25):

Explain exactly why plaintext remote administration is dangerous.

Linkage (20):

Relate this single finding to broader risks (credential theft enabling lateral movement).

Application (20):

Give a concrete migration plan to SSH for this host.

Clarity (10):

Short, direct write-up — this question doesn't need a large table.

Question 5: Netdiscover Host Discovery

Target: 192.168.1.1–50

Perform host discovery with Netdiscover, identify active hosts, and analyze how this information could assist further enumeration or exploitation.

Concepts you need to understand

- Netdiscover uses ARP requests to find live hosts on a local network segment — works even when ICMP ping is blocked.
- Host discovery is the first phase of a penetration test: you can't scan or exploit hosts you don't know exist.
- MAC address vendor lookups can reveal device types (e.g., printers, VoIP phones, hypervisors).

Tools & example command syntax (reference only — run against the authorized lab target given to you)

Netdiscover

Active scan of the given range.

```
netdiscover -r 192.168.1.0/24
netdiscover -i eth0 -r 192.168.1.1-50
```

What your analysis should cover

- List the live IP/MAC pairs discovered and any identifiable vendor/device type.
- Explain how this host list feeds into the next phase: targeted Nmap scans on each live host.
- Discuss risk: unmonitored ARP traffic goes undetected on flat, unsegmented networks, making silent discovery easy for an attacker.
- Recommend defenses: network segmentation/VLANs, ARP monitoring, disabling unused switch ports, intrusion detection for ARP scanning.

Mapping to the rubric — write these sections explicitly

Identification (25):

List every live host found with IP and MAC.

Analysis (25):

Explain what the discovered hosts tell you about the network layout.

Linkage (20):

Show how discovery results directly enable the next attack phase (port scanning/enumeration).

Application (20):

Recommend network-level controls that would have limited this discovery.

Clarity (10):

Table of IP | MAC | Vendor (if resolvable) | Notes.

General Write-Up Checklist Before Submission

- Every command actually run on your assigned lab target, with real screenshots (not copied from this outline).
- A short summary paragraph per question restating the finding in plain language.
- A consolidated table across all 5 questions showing Port/Service | Risk | Recommendation.
- Your name/reg. no. filled into the Code of Conduct and signed.
- Proofread for clarity — this rubric explicitly grades presentation.